Susan Noorzai B-544

1. How does VeriSign verify that a certificate signing request came from the correct entity for their "Secure Site" (not EV) certificates? What are two disadvantages or limitations to using this method of validation?
VeriSign verifies the ownership of a domain by checking that the requester controls the domain listed in the certificate request. They usually confirm this through administrative email verification, a DNS record, or a file placed on the organization's web server. This method only proves that the requester has control of the domain, not that they are a legitimate business or organization. One disadvantage is that an attacker who gains temporary control of a domain could still obtain a valid certificate. Another limitation is that the process does not verify the identity of the organization behind the domain, which reduces trust.

2. **What are Extended Validation certificates? What are two advantages and disadvantages to using them?**
Extended Validation (EV) certificates require a much stricter identity verification process before being issued. The Certificate Authority verifies that the applicant is a legally registered business or organization, that it exists physically and operationally, and that it has the right to use the domain. The advantages of EV certificates are that they provide higher assurance to users and make phishing attacks harder because browsers display the organization's name in the certificate details. The disadvantages are that EV certificates are more expensive and time-consuming to obtain, and many users do not pay attention to the visual cues in their browser, which limits their effectiveness.

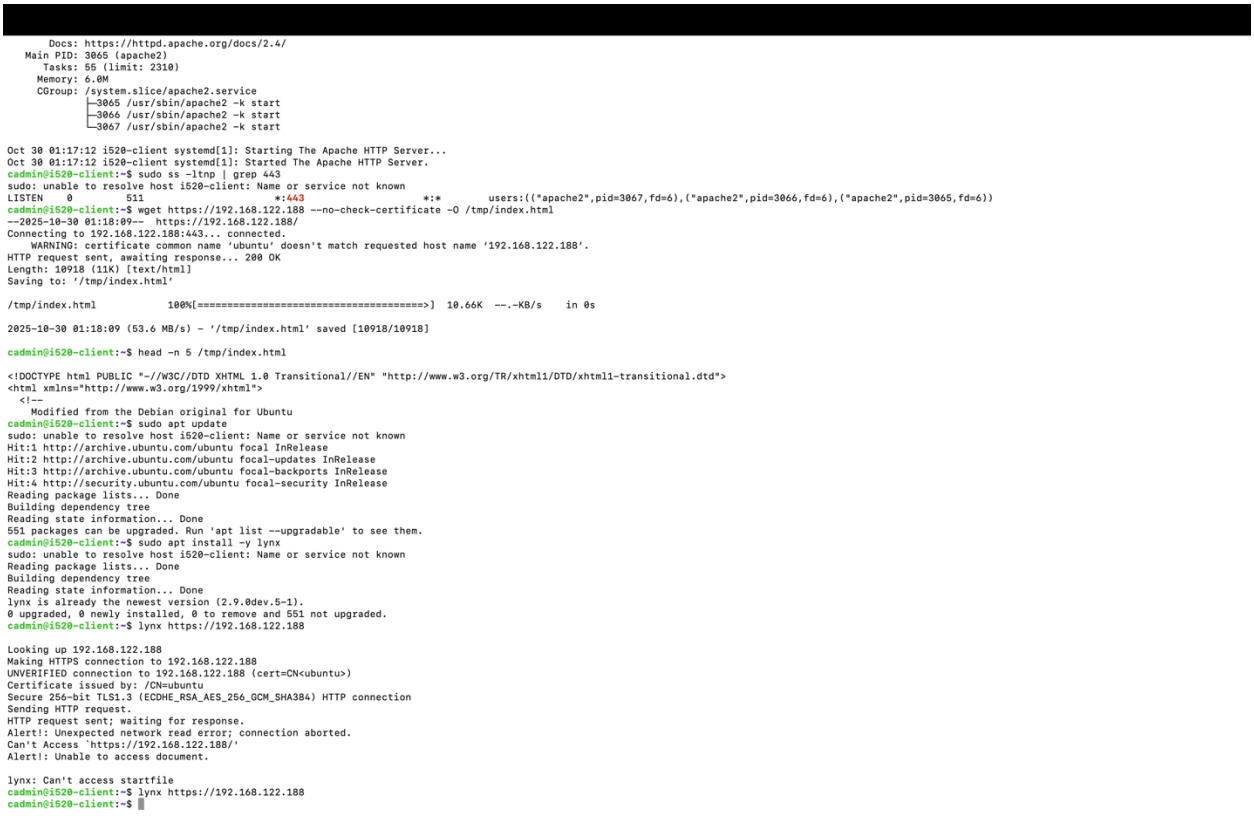
3. What steps could you take to ensure that you have the correct root certificate for VeriSign in your browser?
To make sure that you have the correct root certificate for VeriSign, you should check the certificate's fingerprint (SHA-1 or SHA-256) and compare it with the official fingerprint published by VeriSign or DigiCert. You can also check the issuer name and serial number against trusted sources. The safest way to get the correct root certificate is by relying on your browser or operating system updates, rather than downloading it manually from the internet.

4. Compare and contrast the OCSP and CRL approaches for certificate revocation.
The Certificate Revocation List (CRL) method involves downloading a list of all revoked certificates from the Certificate Authority. This list can become large, and it may not always be up to date between downloads. In contrast, the Online Certificate Status Protocol (OCSP) allows the browser to check the revocation status of a single certificate in real time by querying the CA's server. OCSP provides fresher and faster information, but it also reveals to the CA which websites the user is visiting. CRLs are more privacy-friendly but slower and less efficient.

5. What X.509 field does a browser check to determine if a received certificate is allowed to be used for the site that sends it?
A browser checks the Subject Alternative Name (SAN) field in the certificate to verify whether the domain or IP address matches the site being accessed. If the SAN field is not present, the browser falls back to checking the Common Name (CN) field in the certificate.

6. Why do certificates have an expiration date if there are other certificate revocation mechanisms (like OCSP and CRL)?
Certificates have an expiration date to ensure that they are only trusted for a limited period. This helps prevent long-term misuse of old keys and enforces regular renewal and re-verification of ownership. Expiration also protects against weaknesses in cryptographic algorithms that can develop over time and acts as a backup measure in case revocation mechanisms fail or are not checked properly by browsers.

Here is some of useful screenshots for better understanding of some parts of this lab:



```
|       `-- *.conf
|-- sites-enabled
|       `-- *.conf


    * apache2.conf is the main configuration file. It puts the pieces together by including all
      remaining configuration files when starting up the web server.
    * ports.conf is always included from the main configuration file. It is used to determine the
      listening ports for incoming connections, and this file can be customized anytime.
    * Configuration files in the mods-enabled/, conf-enabled/ and sites-enabled/ directories contain
      particular configuration snippets which manage modules, global configuration fragments, or
      virtual host configurations, respectively.
    * They are activated by symlinking available configuration files from their respective
      *-available/ counterparts. These should be managed by using our helpers a2enmod, a2dismod,
      a2ensite, a2dissite, and a2enconf, a2disconf . See their respective man pages for detailed
      information.
    * The binary is called apache2. Due to the use of environment variables, in the default
      configuration, apache2 needs to be started/stopped with /etc/init.d/apache2 or apache2ctl.
      Calling /usr/bin/apache2 directly will not work with the default configuration.


  Document Roots

  By default, Ubuntu does not allow access through the web browser to any file apart of those located
  in /var/www, public_html directories (when enabled) and /usr/share (for web applications). If your
  site is using a web document root located elsewhere (such as in /srv) you may need to whitelist your
  document root directory in /etc/apache2/apache2.conf.

  The default Ubuntu document root is /var/www/html. You can make your own virtual hosts under
  /var/www. This is different to previous releases which provides better security out of the box.
  Reporting Problems

  Please use the ubuntu-bug tool to report bugs in the Apache2 package with Ubuntu. However, check
  existing bug reports before reporting a new bug.

  Please report bugs specific to modules (such as PHP and others) to respective packages, not to the
  web server itself.
```

```
root                                                                                                                    Done

Enabling conf serve-cgi-bin.
Enabling site 000-default.
Created symlink /etc/systemd/system/multi-user.target.wants/apache2.service → /lib/systemd/system/apache2.service.
Created symlink /etc/systemd/system/multi-user.target.wants/apache-htcacheclean.service → /lib/systemd/system/apache-htcacheclean.service.
Processing triggers for systemd (245.4-4ubuntu3.17) ...
Processing triggers for man-db (2.9.1-1) ...
Processing triggers for ufw (0.36-6ubuntu1) ...
sadmin@i520-server:~$ sudo systemctl enable apache2
Synchronizing state of apache2.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install enable apache2
sadmin@i520-server:~$ sudo systemctl start apache2
sadmin@i520-server:~$ sudo systemctl status apache2
● apache2.service - The Apache HTTP Server
     Loaded: loaded (/lib/systemd/system/apache2.service; enabled; vendor preset: enabled)
     Active: active (running) since Thu 2025-10-30 00:59:01 EDT; 11s ago
       Docs: https://httpd.apache.org/docs/2.4/
   Main PID: 3980 (apache2)
      Tasks: 55 (limit: 2310)
     Memory: 5.6M
     CGroup: /system.slice/apache2.service
             ├─3980 /usr/sbin/apache2 -k start
             ├─3981 /usr/sbin/apache2 -k start
             └─3982 /usr/sbin/apache2 -k start

Oct 30 00:59:01 i520-server systemd[1]: Starting The Apache HTTP Server...
Oct 30 00:59:01 i520-server apachectl[3978]: AH00558: apache2: Could not reliably determine the server's fully qualified >
Oct 30 00:59:01 i520-server systemd[1]: Started The Apache HTTP Server.

sadmin@i520-server:~$ sudo cat /etc/apache2/sites-enabled/000-default.conf
<VirtualHost *:80>
        # The ServerName directive sets the request scheme, hostname and port that
        # the server uses to identify itself. This is used when creating
        # redirection URLs. In the context of virtual hosts, the ServerName
        # specifies what hostname must appear in the request's Host: header to
        # match this virtual host. For the default virtual host (this file) this
        # value is not decisive as it is used as a last resort host regardless.
        # However, you must set it for any further virtual host explicitly.
        #ServerName www.example.com

        ServerAdmin webmaster@localhost
        DocumentRoot /var/www/html

        # Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
        # error, crit, alert, emerg.
        # It is also possible to configure the loglevel for particular
        # modules, e.g.
        #LogLevel info ssl:warn

        ErrorLog ${APACHE_LOG_DIR}/error.log
        CustomLog ${APACHE_LOG_DIR}/access.log combined

        # For most configuration files from conf-available/, which are
        # enabled or disabled at a global level, it is possible to
        # include a line for only one particular virtual host. For example the
        # following line enables the CGI configuration for this host only
        # after it has been globally disabled with "a2disconf".
        #Include conf-available/serve-cgi-bin.conf
</VirtualHost>

# vim: syntax=apache ts=4 sw=4 sts=4 sr noet
sadmin@i520-server:~$ sudo tree -p /opt/CA
/opt/CA
```

```
root                                                                                                                    Done

/opt/CA
├── [-rw-r--r--]  cacert.pem
├── [-rw-r--r--]  caconfig.cnf
├── [drwxr-xr-x]  certs
│   └── [-rw-r--r--]  192.168.122.188.pem
├── [drwxr-xr-x]  crets
├── [-rw-r--r--]  database.txt
├── [-rw-r--r--]  database.txt.attr
├── [-rw-r--r--]  database.txt.old
├── [drwxr-xr-x]  newcerts
│   └── [-rw-r--r--]  01.pem
├── [drwx------]  private
│   └── [-rw-------]  cakey.pem
├── [drwxr-xr-x]  reqs
│   └── [-rw-r--r--]  clientreq.csr
├── [-rw-r--r--]  serial
└── [-rw-r--r--]  serial.old

5 directories, 11 files
sadmin@i520-server:~$ cat /opt/CA/serial
02
sadmin@i520-server:~$ wc -c /opt/CA/database.txt
106 /opt/CA/database.txt
sadmin@i520-server:~$ grep -E '^\s*dir\s*=' /opt/CA/caconfig.cnf
dir             = /opt/CA               # Where everything is kept
dir             = ./demoCA              # TSA root directory
sadmin@i520-server:~$ grep -E '^\s*database\s*=' /opt/CA/caconfig.cnf
database        = $dir/database.txt     # database index file.
sadmin@i520-server:~$ grep -E '^\s*new_certs_dir\s*=' /opt/CA/caconfig.cnf
new_certs_dir   = $dir/newcerts         # default place for new certs.
sadmin@i520-server:~$ grep -E '^\s*certs\s*=' /opt/CA/caconfig.cnf
certs           = $dir/certs            # Where the issued certs are kept
certs           = $dir/cacert.pem       # Certificate chain to include in reply
sadmin@i520-server:~$ grep -E '^\s*copy_extensions\s*=\s*copy' /opt/CA/caconfig.cnf
 copy_extensions = copy
sadmin@i520-server:~$ awk '/\[ *policy_match *\]/{flag=1;next}/^\[/{flag=0}flag' /opt/CA/caconfig.cnf | egrep 'countryName|stateOrProvinceName|organizationName'
countryName             = optional
stateOrProvinceName     = optional
organizationName        = optional
sadmin@i520-server:~$ openssl x509 -in /opt/CA/cacert.pem -text -noout | head -20
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number:
            23:42:f3:ef:d2:27:98:9b:0b:a7:c8:27:bf:47:c5:b3:99:ac:5f:04
        Signature Algorithm: sha256WithRSAEncryption
        Issuer: C = US, ST = Bloomington, L = Bloomington, O = snoorzai_CA, CN = susan, emailAddress = snoorzai@iu.edu
        Validity
            Not Before: Oct 29 20:45:50 2025 GMT
            Not After : Dec 28 20:45:50 2025 GMT
        Subject: C = US, ST = Bloomington, L = Bloomington, O = snoorzai_CA, CN = susan, emailAddress = snoorzai@iu.edu
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
                RSA Public-Key: (2048 bit)
                Modulus:
                    00:ac:a4:ab:9a:07:11:46:29:31:de:1c:55:ff:57:
                    60:cb:80:e2:d5:d9:4f:23:de:5f:15:73:ba:1c:2d:
                    02:c6:bd:f7:47:c7:e5:41:a3:b7:b2:71:e0:83:10:
                    75:b3:de:33:a0:27:17:1a:6a:f1:af:37:f7:d0:7d:
                    6f:b2:4c:fc:38:d1:c3:dc:f4:0d:52:91:ba:f7:4a:
sadmin@i520-server:~$
```